

Cyber Crime Case Studies

Name: Chauhan Soham
Enrollment: 241105060016

A detailed analysis of real-world cyber incidents, their impact and key lessons for a safer digital future.

CASE 1 — EQUIFAX DATA BREACH (USA)



Farewell to a Justice

Record Data Breach Settlement Will Cost Equifax $650 Million

A Cry Pierces Museums' Hush: Raise Our Pay

The Mountain Enterprise clipping dated 15 September 2017 reports that the Equifax breach endangered the information of approximately 143 million people.

IMAGE DESCRIPTION

The clipping reports a major breach at Equifax, one of the United States' large credit-reporting agencies. Personal information held by the company was exposed, creating long-term risks of identity theft and financial fraud.

1) NEWS HISTORY — WHAT HAPPENED?

In 2017, attackers exploited a known vulnerability in an internet-facing Apache Struts web application. Equifax had not applied the available security update in time. The attackers accessed company systems and remained undetected for weeks. Equifax publicly announced the incident in September 2017. The initially reported figure was about 143 million U.S. consumers; subsequent investigations put the total at roughly 147 million people.

SOURCE / NEWS REFERENCE

The Mountain Enterprise, 15 September 2017, "Vast Equifax data breach endangers half of U.S. population—143 million." Additional factual reference: U.S. Federal Trade Commission, Equifax data breach settlement (2019).

2) ATTACK TECHNIQUE

The central technique was exploitation of an unpatched web-application vulnerability. After gaining access, the attackers were able to reach systems containing sensitive data and extract records. The incident is not generally described as a confirmed phishing-led attack.

3) TOTAL LOSS / FINANCIAL IMPACT

Exposed data included names, dates of birth, Social Security numbers, addresses and, for some people, driver's licence numbers and payment-card information. The exposure increased the risk of identity theft, fraudulent credit applications and targeted scams. The harm was difficult to reverse because many identifiers cannot simply be changed.

4) RECOVERY — COMPANY / AUTHORITY RESPONSE

Equifax brought in external cybersecurity specialists, notified consumers and offered credit monitoring and identity-protection services. The company faced investigations, lawsuits and regulatory action. It also made leadership changes and announced improvements to security governance, vulnerability management and monitoring.

5) RECOVERY COST AND RECOVERY TIME

A U.S. Federal Trade Commission-led settlement announced in 2019 required Equifax to provide at least $575 million in relief and could reach $700 million, depending on claims and other conditions. This settlement is not a precise measure of the company's total technical recovery cost. Legal, remediation and consumer-support work continued for years.

6) HOW COULD IT HAVE BEEN PREVENTED?

Apply critical security patches promptly; maintain an accurate inventory of internet-facing software; scan and test exposed applications; segment databases from web servers; encrypt sensitive data; use least-privilege access; monitor unusual queries and large data transfers; and rehearse incident response.

SOLUTION / KEY LESSON

A known vulnerability can become a major breach when patching, asset visibility and detection fail together. Security updates must be verified, not merely announced, and sensitive information should be protected by multiple independent controls.

CASE 2 — OPTUS DATA BREACH AND CYBERSECURITY READINESS (AUSTRALIA)



FINANCIAL REVIEW

China crossed line with malware attack: cyber chief

Andrew Tillett
National correspondent

China has "crossed a line" with its state-sanctioned hacking of Microsoft Exchange email servers, Australia's top cyber security official says, because it opens the door to criminals to exploit the vulnerability.

Australian Signals Directorate chief Rachel Noble told a parliamentary inquiry that an estimated 70,000 Australian businesses used Microsoft Exchange servers that had reportedly had been exposed earlier this year.

Australia joined almost 40 countries last week, including the US, Japan and European Union, to name Beijing as the culprit behind the widespread cyber intrusions.

Although China has denied responsibility, Ms Noble told the inquiry it was an "extremely large and significant" attack.

"To explain it in plain language, it is like China has crossed a line and left the big faulty locks on the doors," she said.

"When the Chinese government became aware of the faulty locks on the doors, they went in and they propped all those doors open.

"It's that action from a technical point of view which crossed a line in the judgment of policy agencies and governments around the world."

Home Affairs Department Secretary Mike Pezzullo said Australia was actively engaged in developing global "cyber norms".

"Such reckless action should not be tolerated as a matter of international and global norms, and that's why the Australian government joined with such a significant coalition of free democratic nations," he said.

Attorney-General Mark Dreyfus QC and Home Affairs Minister James Paterson. Mr Pezzullo agreed that ransomware attacks were not just the preserve of criminal gangs, and that countries might be involved.

Ms Noble and Mr Pezzullo were appearing before a parliamentary joint committee on intelligence and security that has proposed legislation to protect critical infrastructure from cyber attacks.

The new powers include giving government agencies the power to "step in" when companies refuse to act on a threat, and imposes new reporting requirements to inform agencies of cyber attacks and security risks as soon as practicable. Industry representatives and technology groups have raised concerns about how the new regimen would work, including the compliance burden.

Mr Pezzullo said the legislation was "principles-based" rather than duplicate existing regulation.

He said the Home Affairs minister could declare a positive service obligation for a critical infrastructure provider to take action to protect itself, but only after consultation with the sector and relevant regulators.

Mr Pezzullo said the minister would use powers to take charge of a network "as a last resort" only if they were satisfied the infrastructure provider was "unwilling" to protect itself.

Rachel Noble, Australian Signals Directorate, above

When [China] became aware of the faulty locks on the doors, they went in and they propped all those doors open.

The Herald Sun clipping discusses cyber-security workforce funding and the response to the Optus data breach. The article's main topic is also policy and workforce readiness, not only the technical intrusion.

IMAGE DESCRIPTION

The newspaper clipping links the Optus breach to wider concerns about Australia's ability to protect personal information and build a skilled cyber-security workforce. It describes a data breach affecting customers and the debate over funding and security capability.

2) NEWS HISTORY — WHAT HAPPENED?

In September 2022, Australian telecommunications provider Optus disclosed that customer information had been accessed by an unauthorised party. Public reporting and regulatory investigations described the exposure of personal details associated with current and former customers. The information involved varied by person and could include names, dates of birth, phone numbers, email addresses, and identity-document numbers. Public reporting often cited up to around 9.8 million records or people in connection with the incident; that figure should not be read as meaning every person had every data field exposed.

SOURCE / NEWS REFERENCE

Herald Sun clipping supplied with this assignment, headline "Hacked off by cyber freeze." Contextual incident: Optus customer-data breach, publicly disclosed in September 2022. The supplied clipping is used as the image/article reference; technical details above are carefully qualified where the clipping does not establish them.

2) ATTACK TECHNIQUE

The breach involved unauthorised access to an exposed Optus-facing application interface. Public accounts raised concerns about access controls and whether the interface was adequately protected. The exact technical pathway and responsibility for every exposed record should be attributed to official findings rather than assumed from a newspaper headline. There is no basis here to label the incident as a confirmed phishing attack.

3) TOTAL LOSS / FINANCIAL IMPACT

The disclosure raised risks of identity fraud, impersonation, phishing and misuse of identity-document numbers. Customers had to assess whether to replace documents or take extra precautions. The incident also triggered intense scrutiny of data retention, API security, privacy practices and how telecommunications providers protect customer records.

4) RECOVERY — COMPANY / AUTHORITY RESPONSE

Optus notified customers and worked with Australian authorities. Government agencies and regulators examined the incident and its consequences, while affected people were advised to watch for suspicious contact and consider relevant identity-protection steps. The event accelerated public debate about limiting the amount of personal data retained and improving information-sharing during cyber incidents.

5) RECOVERY COST AND RECOVERY TIME

A single definitive public figure for the total technical recovery cost is not established in the supplied clipping. The overall impact included investigation, customer support, potential legal and regulatory costs, identity-document replacement measures and reputational damage. Any precise financial estimate should be tied to a dated company filing or official regulatory statement.

6) HOW COULD IT HAVE BEEN PREVENTED?

Require authentication and authorisation for every sensitive API; restrict public access to customer-data endpoints; minimise retained identity data; rate-limit and monitor requests; test APIs for unauthorised enumeration; encrypt records; and establish a rehearsed breach-notification process. Cybersecurity workforce training and clear accountability are also important.

SOLUTION / KEY LESSON

Cybersecurity depends on both secure technology and organisational readiness. Companies should collect only necessary data, verify access controls continuously and respond quickly and transparently when personal information may be exposed.

CASE 3 — MALWARE / WEBSITE COMPROMISE (LOS ANGELES TIMES CONTEXT)



The supplied Los Angeles Times-style clipping uses the headline "Malware Attack!" and an image of a hooded attacker. Treat the graphic as an illustration; it does not by itself prove the exact incident described in the headline.

IMAGE DESCRIPTION

The article image presents malware as a threat to news organisations and their digital services. Malware can alter a website, redirect visitors, steal credentials, spy on users or misuse visitors' computers. For accuracy, this case distinguishes the supplied illustrative clipping from independently established incident details.

3) NEWS HISTORY — WHAT HAPPENED?

The supplied clipping is dated in a way that is difficult to reconcile with a verifiable original Los Angeles Times report, and its headline and layout should not be treated as conclusive evidence of a real database breach. A separately reported 2018 issue involving the Los Angeles Times concerned malicious cryptocurrency-mining code on a webpage, often described as cryptojacking. That type of incident abuses visitors' computing resources and is different from a confirmed theft of the newspaper's subscriber database. The precise claims in the supplied image are therefore not presented as verified facts.

SOURCE / NEWS REFERENCE

Supplied Los Angeles Times-style image, headline "Malware Attack!" (used as an illustrative article image). For the related category of threat, see public reporting from 2018 on cryptojacking code affecting a Los Angeles Times webpage; the supplied clipping itself is not treated as proof of that event.

2) ATTACK TECHNIQUE

Malware is malicious software or code. In a website compromise, an attacker may exploit a vulnerable content-management system, steal administrator credentials, alter a script or abuse a misconfigured cloud storage account. Cryptojacking code runs unauthorised cryptocurrency-mining scripts in a visitor's browser. These are possible techniques for this category of incident, not a claim that every method occurred in the supplied clipping.

3) TOTAL LOSS / FINANCIAL IMPACT

Potential effects include slow website performance, increased computing costs, service interruption, exposure to malicious redirects and loss of reader trust. If credentials or personal data are also stolen, the consequences may include account takeover and fraud. The supplied image does not establish a reliable financial-loss figure or a confirmed count of affected users.

4) RECOVERY — COMPANY / AUTHORITY RESPONSE

A responsible response would isolate affected systems, remove unauthorised code, preserve logs for investigation, rotate credentials and keys, patch vulnerable components, verify clean backups and review cloud permissions. The organisation should inform users or regulators when evidence shows their data or safety was affected. For the specific clipping, no verified recovery timeline or cost is established.

5) RECOVERY COST AND RECOVERY TIME

No reliable single loss amount or recovery duration can be confirmed from the supplied image. Costs depend on the duration of compromise, traffic, forensic work, service restoration, legal obligations and reputational harm. It would be misleading to assign a precise dollar figure without a verifiable incident report.

6) HOW COULD IT HAVE BEEN PREVENTED?

Keep content-management systems and plugins updated; use multi-factor authentication for administrators; apply least privilege to cloud accounts; protect deployment credentials; use content-security policies and file-integrity monitoring; scan pages for injected scripts; and monitor abnormal CPU use and outbound connections.

SOLUTION / KEY LESSON

A dramatic headline is not a substitute for verification. In cyber incident reporting, distinguish confirmed facts from illustrations or allegations. Technically, layered controls and continuous monitoring can help detect malicious code before it harms many users.

CASE 4 — CYBER FRAUD, DOMAIN IDENTITY CHECKS AND PAYMENT SAFETY (INDIA)



‘Privacy By Default’ Won’t Do: HC Demands Action On Cyber Fraud

High Court Mandates Strict E-KYC Verification For Domain Name Registrants

Abhinav.Garg@timesofindia.com

New Delhi: Introducing additional safeguards to shield unsuspecting consumers against cyber fraud, Delhi High Court has mandated strict e-KYC verification of domain name registrants (DNR). It said laxness in identity checks by them had contributed to the proliferation of online fraud, phishing websites and large-scale digital offences.

In a recent judgment on a batch of suits filed by Dabur India Ltd, Justice Prathiba M Singh observed that anonymity in domain registrations enabled the misuse of well-known brands. This resulted in people being misled. It also allowed cheats to siphon off money through fake franchises, distributorships and investment schemes.

The court ordered that all DNRs offering services in India must go for mandatory verification of details at the time of registration and periodic re-verification after that, following KYC requirements given in a govt circular of April 28, 2022.

It said the current practice of “privacy by default” cannot be accepted and stressed that masking registrant details without verified credentials had become a key enabler of financial fraud. It issued a string of directions to the banks and govt also. Justice Singh observed that offering anonymity at the registration stage made it nearly impossible for brand owners, banks and law enforcement agencies to trace offenders in time.

“The offering of privacy by default to registrants is one of the reasons for the proliferation of illegal domain names,” the court said, specifying that unless an entity specifically opts for privacy protection after completing verification, personal details cannot be concealed.

The court said all DNRs must clarify which data is to be shared with National Internet Exchange of India (NIXI) with respect to domains administered by it. Updates should be done monthly.

The court asked all banks to mandatorily implement the Beneficiary Bank Account Name Lookup facility, according to an RBI circular dated Dec 30, 2024, for all online payments, including payments by UPI through Google Pay, Paytm and other such apps.

“All banks shall also abide by the standard operating procedures dated May 31, 2024, issued by the Central Economic Intelligence Bureau for processing, and respond to requests from law enforcement agencies,” the court added.

It noted that once a customer looks up the name of the beneficiary, there is less chance of her being defrauded.

Upon a request by courts or agencies, DNRs must disclose verified details, including name, address, number, email ID and payment information, in 72 hours, the court said.

It cautioned that the failure to comply with these KYC norms and disclosure obligations could result in registrants losing their protection under the Information Technology Act, 2000 (IT Act). They could also face blocking under Section 69A.

“There is an urgent necessity for directions to be passed to ensure that the trust of consumers, as also the interest of businesses are protected, and no party is permitted to commit fraud due to the failure of sufficient safeguards in the system,” it observed.

The court also asked the Centre to explore a uniform e-KYC framework, similar to the one followed by NIXI.

“Govt shall hold stakeholder consultations with all DNRs and registry operators offering services and explore the possibility of putting in place a framework similar to NIXI by all DNRs,” the high court added.

#DontGetScammed
Gift TOI to your loved ones and protect them from scams. Call 85 95 124 124

HC SAYS
Banks must implement Beneficiary Bank Account Name Lookup facility according to the RBI circular dated Dec 30, 2024, for all online payments

The supplied news clipping discusses stronger e-KYC checks for domain-name registrants and measures intended to reduce cyber fraud and payment scams.

IMAGE DESCRIPTION

This clipping focuses on prevention and regulation rather than a single named company breach. It reports calls for stronger identity verification for domain-name registrants and for banks to adopt beneficiary-name checks, aiming to make online fraud harder to carry out anonymously.

4) NEWS HISTORY — WHAT HAPPENED?

Online fraud frequently relies on fake websites, impersonation, phishing messages and payment instructions that appear to come from a trusted organisation. A fraudster may register a look-alike domain, create a convincing login page or persuade a victim to transfer money to a mule account. The supplied article describes judicial and policy attention to identity verification and payment checks. It should not be interpreted as proof that one specific attack or one quantified loss occurred.

SOURCE / NEWS REFERENCE

Supplied Indian news clipping: “‘Privacy By Default’ Won’t Do: HC Demands Action On Cyber Fraud,” reporting on e-KYC for domain registrants and beneficiary-account name lookup. The clipping is treated as a policy report; no unverified case-specific loss figure is added.

2) ATTACK TECHNIQUE

Relevant techniques include typosquatting (registering a domain similar to a genuine one), phishing, spoofed emails or messages, fake customer-support pages and social engineering that persuades victims to reveal credentials or approve transfers. Beneficiary-account name checks can help identify a mismatch between the intended recipient and the account name, but they cannot stop every scam.

3) TOTAL LOSS / FINANCIAL IMPACT

Victims may lose money, disclose passwords or identity documents, or have accounts taken over. Businesses can suffer impersonation, customer distrust and incident-response costs. The supplied clipping does not provide a defensible total loss figure for one incident; the impact varies across individual fraud cases.

4) RECOVERY — COMPANY / AUTHORITY RESPONSE

The article reports a push for stricter electronic know-your-customer checks for domain registrants and improved bank-side beneficiary-name verification. In an actual fraud case, victims should contact their bank immediately, report the transaction to the appropriate cybercrime reporting channel and preserve messages, URLs, account details and transaction references. Organisations should take down impersonating domains through the registrar or hosting provider where appropriate.

5) RECOVERY COST AND RECOVERY TIME

No single recovery cost or time is established because this is a policy-focused report, not a single breach report. Some transfers may be frozen or recovered if reported quickly, while others may be difficult to reverse. Prevention, reporting speed and cooperation between banks, registrars and law enforcement influence outcomes.

6) HOW COULD IT HAVE BEEN PREVENTED?

Use clear domain-registration identity checks; monitor look-alike domains; deploy email authentication such as SPF, DKIM and DMARC; use phishing-resistant multi-factor authentication; verify payment changes through a separate trusted channel; apply beneficiary-name checks; and train staff to recognise urgency, secrecy and unexpected payment requests.

SOLUTION / KEY LESSON

Identity checks and payment verification add useful friction to fraud, but must be combined with user awareness, fast reporting and cooperation among banks, registrars, platforms and law enforcement. No single check eliminates cyber fraud.

CASE 5 — ALLEGED DRDO DOCUMENTS OFFERED ON THE DARK WEB (INDIA)



In chilling 'digital detention' scams, cybercriminals pose as cops, CBI, ED

THE UNSUSPECTING GIVE IN TO ONLINE 'INTERROGATIONS'

TIMES Special

The supplied news clipping reports an allegation that DRDO-related documents were offered for sale on the dark web, while noting that defence sources were checking authenticity.

IMAGE DESCRIPTION

The article describes a potential national-security information exposure. Its wording is important: the report says the documents were allegedly offered for sale and that their authenticity was being verified. That means the allegation should not be presented as a confirmed theft of classified DRDO files.

5) NEWS HISTORY — WHAT HAPPENED?

According to the supplied clipping, a threat actor allegedly advertised a collection of documents said to relate to India's Defence Research and Development Organisation. Defence sources were reportedly checking whether the material was genuine and whether it contained restricted technical information. A listing on a dark-web forum does not, on its own, prove that the documents are authentic, classified, current or stolen from the named organisation. Those questions require forensic and official verification.

SOURCE / NEWS REFERENCE

Supplied news clipping: "31GB of DRDO data available for sale on dark web for $8K: Report," which explicitly says authenticity was being verified. This case study preserves that uncertainty and does not state that a confirmed breach occurred.

2) ATTACK TECHNIQUE

If sensitive documents are exposed, possible pathways can include compromised employee credentials, phishing, malware, exploitation of an unpatched system, insecure file-sharing, misconfigured storage or an insider copying information. The clipping does not establish which, if any, of these techniques occurred. The responsible conclusion is that the alleged source and method remained unconfirmed in the report.

3) TOTAL LOSS / FINANCIAL IMPACT

If genuine restricted defence material were exposed, possible consequences could include disclosure of research plans, technical capabilities, procurement details or internal processes. Such information might help hostile actors or harm operational security. If the documents are fabricated, public claims could still create reputational damage and consume investigative resources. The supplied article does not establish a verified number of affected records or a confirmed financial loss.

4) RECOVERY — COMPANY / AUTHORITY RESPONSE

The response described in the clipping was to verify the documents' authenticity and assess their sensitivity. A sound investigation would preserve the advertised samples and metadata, compare files against authoritative records, identify any matching internal access logs, assess whether systems or accounts were compromised and coordinate with relevant cyber-security and law-enforcement teams. Public statements should avoid confirming unverified claims prematurely.

5) RECOVERY COST AND RECOVERY TIME

The clipping does not establish a verified recovery cost or recovery timeline. If an exposure were confirmed, costs could include digital forensics, containment, credential resets, system hardening, security reviews and long-term monitoring. The potential national-security consequences may be more significant than direct financial losses, but should not be quantified without evidence.

6) HOW COULD IT HAVE BEEN PREVENTED?

Classify documents by sensitivity; enforce least-privilege access; use multi-factor authentication; encrypt files at rest and in transit; monitor bulk downloads and unusual access; prevent unauthorised removable-media transfers; audit third-party access; maintain secure backups; and conduct regular insider-risk and incident-response reviews.

SOLUTION / KEY LESSON

Allegations must be verified before they are treated as facts. For sensitive organisations, document classification, strict access control, monitoring and disciplined incident handling are essential. Public reporting should clearly separate confirmed evidence from claims under investigation.